

GMX · SECURITY REVIEW

GMX Config Syncer.

A security review of Config Syncer.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
GMX	Config Syncer	Guardian	August 20 – August 28, 2024	September 4, 2024

§ 00

Contents.

18 pages — overview, confidence ranking, scope, 7 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 5 findings	P. 08
	Remediation Review · 2 findings	P. 14
§ 05	Disclaimer	P. 17
§ 06	About Guardian	P. 18

§ 01

Overview.

Guardian reviewed Config Syncer across 2 review rounds. The final report includes 7 Low findings.

AUDIT FIRM	REPOSITORY
Guardian	gmx-io/gmx-synthetics
CLIENT	METHODOLOGY
GMX	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
Config Syncer	d596c9874b5e
PREPARED BY	
Guardian	
AUDIT WINDOW	
August 20 – August 28, 2024	
FINAL REPORT	
September 4, 2024	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	7	0	0	0	7
Informational	0	0	0	0	0
All severities	7	0	0	0	7

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Config Syncer in `gmx-io/gmx-synthetics`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	Duplicate allUpdateTypes Entries	Validation	LOW	RESOLVED	p. 8
L-02	Incorrect previousValue Stored	Logical Error	LOW	RESOLVED	p. 9
L-03	getLatestUpdateByType DoS	DoS	LOW	RESOLVED	p. 10
L-04	Lacking Market Validation	Validation	LOW	RESOLVED	p. 11
L-05	General Key Risk	Validation	LOW	RESOLVED	p. 12
REMEDIATION REVIEW					
L-01	Missing Allowed Keys	Warning	LOW	RESOLVED	p. 14
L-02	Additional Allowed Keys	Warning	LOW	RESOLVED	p. 16

LOW **L-01**

RESOLVED

Duplicate allUpdateTypes Entries

CATEGORY Validation
LOCATION RiskOracle.sol: 59
REVIEW Main Review

DESCRIPTION

In the constructor for the `RiskOracle` contract on Arbitrum Sepolia <https://sepolia.arbiscan.io/address/0x526d6789fCb503F2F898f45912A7a24fe9dd48e4#code>, a list of `initialUpdateTypes` may be passed where there are duplicate `updateType` strings. In this case the `updateType` string will be pushed to the `allUpdateTypes` list multiple times.

This can lead to unexpected behavior for any systems relying on the `allUpdateTypes` list as it will have duplicate entries.

RECOMMENDATION

Consider validating that no duplicate entries have been made for the `updateTypes` in the `RiskOracle` constructor.

RESOLUTION

Status: Resolved.

LOW **L-02**

RESOLVED

Incorrect previousValue Stored

CATEGORY Logical Error
LOCATION RiskOracle.sol: 151
REVIEW Main Review

DESCRIPTION

When creating the `newUpdate` object to be stored the `previousValue` is declared as the direct previous update no matter what market or updateType the previous update acted upon.

This is incorrect or at least misleading as the `previousValue` serves little to no value if it merely references the previous update of any market/parameter. Instead the `previousValue` should pertain to the previous value of the market and `updateType` combination.

RECOMMENDATION

Query the last update for the particular market and parameter type via the `latestUpdateIdByMarketAndType` mapping and store this value as the `previousValue`.

RESOLUTION

Status: Resolved.

LOW **L-03**

RESOLVED

getLatestUpdateByType DoS

CATEGORY	DoS
LOCATION	RiskOracle.sol: 170
REVIEW	Main Review

DESCRIPTION

The `getLatestUpdateByType` function loops backwards through the `updateHistory` to find the most recent matching entry for the `updateType`.

This can lead to an out of gas DoS for integrating contracts if a particular `updateType` has been performed before many other subsequent updates.

RECOMMENDATION

Be aware of this risk and avoid using the `getLatestUpdateByType` function in a Smart Contract. Otherwise consider refactoring the `RiskOracle` such that it stores the `latestUpdateByType` in a mapping so it can be easily queried.

RESOLUTION

Status: Resolved.

LOW **L-04**

RESOLVED

Lacking Market Validation

CATEGORY	Validation
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

Throughout the GMX contracts a common pattern for configuration keys is to include the market which is being targeted in the additional key data.

In the `RiskOracle` and `ConfigSyncer` it is assumed that the market which an update is supplied for is the one which it's provided `additionalData` includes, however there is no validation to enforce this.

RECOMMENDATION

Be aware of this risk and put in place validations off-chain such that trusted parties will not commit updates for markets which are not included in the `additionalData` provided.

Otherwise consider implementing validations at the contract level which do not allow market configurations which do not agree with the market address provided in the `additionalData`. Though this is likely not realistic to validate on-chain due to the many existing arbitrary key datas + new keys which will be introduced in the future.

RESOLUTION

Status: Resolved.

<https://github.com/gmx-io/gmx-synthetics/pull/28/commits/e9807e26dfb2099a6bd555a06ef7cce4d469e648>

LOW **L-05**

RESOLVED

General Key Risk

CATEGORY	Validation
LOCATION	Config.sol
REVIEW	Main Review

DESCRIPTION

The following keys are not validated in the `_validateRange` function and belong to `uint` values which can potentially DoS or otherwise cause loss or harm to GMX V2 users.

- `MAX_SWAP_PATH_LENGTH`
- `MIN_POSITION_SIZE_USD`
- `MAX_POSITION_IMPACT_FACTOR_FOR_LIQUIDATIONS`
- `MAX_ORACLE_PRICE_AGE`
- `MAX_ORACLE_TIMESTAMP_RANGE`
- `ORACLE_TIMESTAMP_ADJUSTMENT`
- `MAX_ORACLE_REF_PRICE_DEVIATION_FACTOR`
- `REQUEST_EXPIRATION_TIME`
- `MIN_COLLATERAL_FACTOR_FOR_OPEN_INTEREST_MULTIPLIER`
- `POSITION_IMPACT_FACTOR`
- `MAX_POSITION_IMPACT_FACTOR`
- `SWAP_IMPACT_FACTOR`
- `MAX_AUTO_CANCEL_ORDERS`
- `RESERVE_FACTOR`
- `OPEN_INTEREST_RESERVE_FACTOR`
- `MIN_FUNDING_FACTOR_PER_SECOND`
- `THRESHOLD_FOR_STABLE_FUNDING`
- `THRESHOLD_FOR_DECREASE_FUNDING`
- `PRICE_FEED_HEARTBEAT_DURATION`
- All gas related keys

RECOMMENDATION

Carefully consider the risk of each of these keys being configured by the `RiskOracle` without any range validation. Where appropriate add the corresponding validations that the configured values are within an expected range.

L-05 General Key Risk

CONTINUED

— RESOLUTION

Status: Resolved.

LOW **L-01**

RESOLVED

Missing Allowed Keys

CATEGORY	Warning
LOCATION	ConfigSyncer.sol
REVIEW	Remediation Review

DESCRIPTION

In the `_initAllowedBaseKeys` several keys have been excluded which are present in the `MockRiskOracle` file.

Missing Keys from `allowedBaseKeys` :

- `SWAP_FEE_FACTOR`
- `ATOMIC_SWAP_FEE_FACTOR`
- `TOKEN_TRANSFER_GAS_LIMIT`
- `MIN_COLLATERAL_FACTOR`
- `MIN_COLLATERAL_FACTOR_FOR_OPEN_INTEREST_MULTIPLIER`
- `MAX_PNL_FACTOR`
- `MIN_PNL_FACTOR_AFTER_ADL`
- `FUNDING_FACTOR`
- `FUNDING_EXPONENT_FACTOR`
- `THRESHOLD_FOR_STABLE_FUNDING`
- `THRESHOLD_FOR_DECREASE_FUNDING`
- `POSITION_FEE_FACTOR`
- `MAX_POSITION_IMPACT_FACTOR_FOR_LIQUIDATIONS`
- `MAX_POSITION_IMPACT_FACTOR`

These keys may be desired to be configured yet have not been allowed in the `_initAllowedBaseKeys` function.

Also notably, The `MAX_PNL_FACTOR` key is present in the `_validateMarketInData` function, but not in the `_initAllowedBaseKeys` function.

RECOMMENDATION

Consider adding some or all of these keys to the `_initAllowedBaseKeys` function, and be aware of the risk if they are not currently validated in the `Config._validateRange` function.

L-01 Missing Allowed KeysCONTINUED

— RESOLUTION

Status: Resolved.

LOW **L-02**

RESOLVED

Additional Allowed Keys

CATEGORY	Warning
LOCATION	ConfigSyncer.sol
REVIEW	Remediation Review

DESCRIPTION

A few keys have been marked as allowed which are not included in the `MockRiskOracle` contract. This may be entirely expected, this finding only serves to point out this detail out of an abundance of caution that some keys may be unexpectedly allowed.

- `OPTIMAL_USAGE_FACTOR`
- `BASE_BORROWING_FACTOR`
- `ABOVE_OPTIMAL_USAGE_BORROWING_FACTOR`

RECOMMENDATION

Consider if these keys are expected to be allowed in the `ConfigSyncer`.

RESOLUTION

Status: Resolved.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.